

• SECURITY AWARENESS TRAINING

Phishing Attacks

How to recognize, resist, and report social engineering threats

Module 1 of 1

16 Slides

- DEFINITION

What Is Phishing?

Phishing is a cyberattack that uses deceptive messages — email, SMS, or voice — to trick people into revealing sensitive information or clicking malicious links.



Email

Most common vector — fake sender addresses and urgent requests



SMS / Vishing

Text messages and phone calls impersonating trusted sources



Fake Sites

Cloned websites designed to harvest login credentials

- THE THREAT LANDSCAPE

Phishing by the Numbers

91%

of cyberattacks begin with a phishing email

3.4B

phishing emails sent every single day worldwide

\$4.9M

average cost of a phishing-related data breach

17s

median time for the first person to click a phishing link

Types of Phishing Attacks

Email Phishing

Bulk deceptive emails mimicking legitimate brands like banks or tech companies

Spear Phishing

Highly targeted attacks using personal details — your name, job, or recent activity

Whaling

Spear phishing aimed specifically at executives, CFOs, or high-value targets

Smishing

SMS-based phishing — fake delivery alerts, bank warnings, prize notifications

Vishing

Voice phishing — phone calls pretending to be IT support, IRS, or your bank

Clone Phishing

Duplicating a real email you received, replacing links with malicious ones

- DETECTION

Red Flags in Emails

! Mismatched sender address

Display name says "PayPal" but email is from paypal-security@gmail.com

! Urgent or threatening language

"Your account will be suspended in 24 hours" — pressure tactics force hasty decisions

! Suspicious links or attachments

Hover over links before clicking — the actual URL rarely matches what's shown

! Generic greetings

"Dear Customer" or "Dear User" instead of your actual name

! Spelling and grammar errors

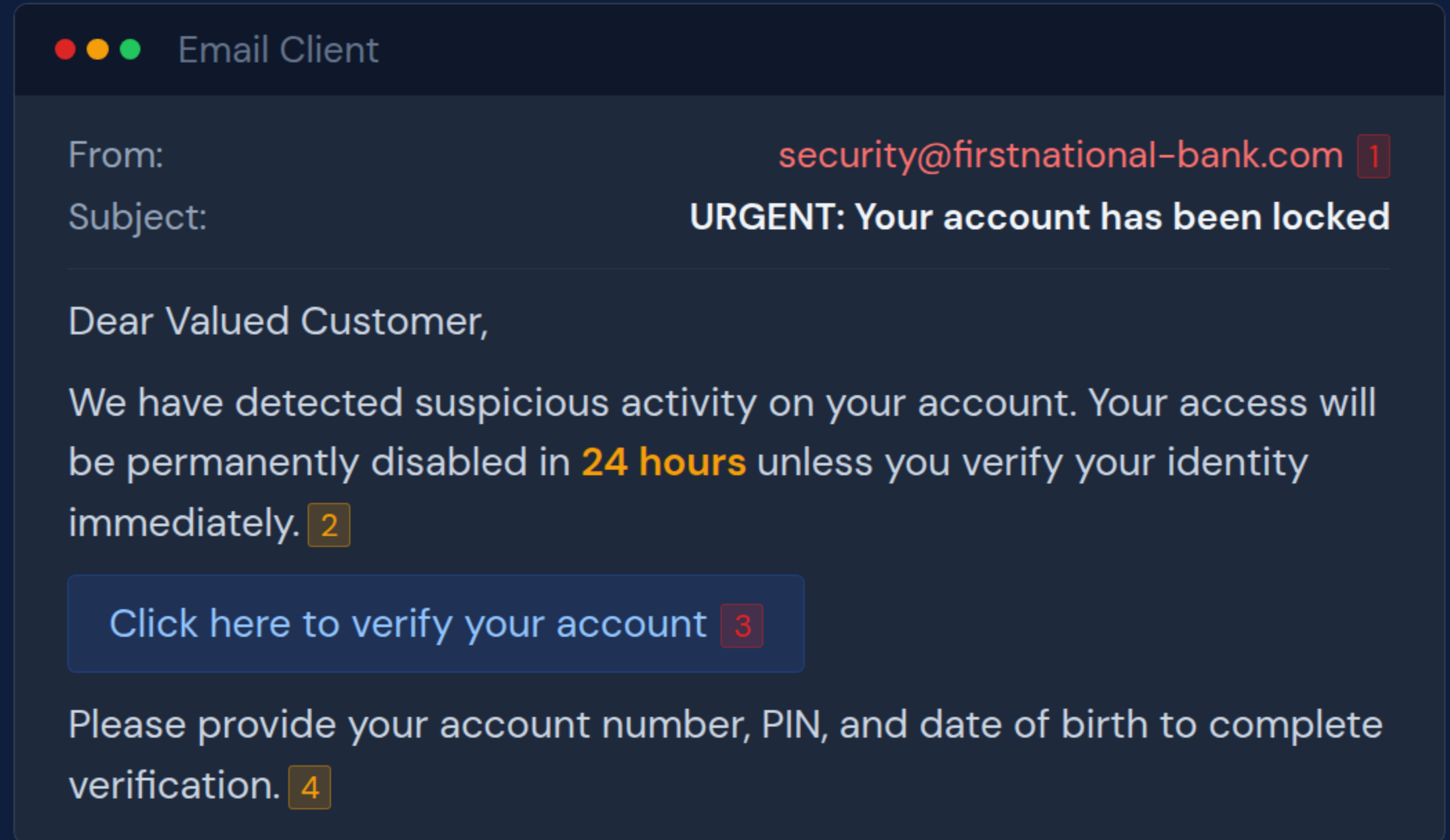
Legitimate organizations proofread carefully — errors are a consistent warning sign

• REAL EXAMPLE

Anatomy of a Phishing Email

This example mimics a common bank security alert. Each numbered callout highlights a deceptive tactic.

- 1 Spoofed domain — nearly identical to the real one
- 2 Manufactured urgency to bypass critical thinking
- 3 Link text hides the real destination URL
- 4 Requesting personal details no bank would ask via email



Spotting Fake Websites

Signs of a Fake Site

URL uses HTTP instead of HTTPS

Subtle domain misspellings: amazOn.com, paypal.com

Wrong domain suffix: paypal-secure.net instead of paypal.com

Broken images, misaligned layout, or pixelated logos

No contact info, missing privacy policy or terms

Safe Site Indicators

HTTPS padlock icon in the browser address bar

Domain exactly matches the company's official domain

Reachable from the company's official communications

Consistent professional design, no broken elements

Verified through Google Safe Browsing or VirusTotal

Remember: A padlock only means the connection is encrypted — not that the site is legitimate. Attackers use HTTPS too.

Social Engineering Tactics

Authority

Impersonating CEOs, IT staff, government agencies, or banks to command immediate compliance

Urgency

Creating artificial time pressure — "Act now or lose access" — to prevent rational decision-making

Scarcity

Claiming limited availability — "Only 1 spot left!" — to trigger impulsive action

Social Proof

Referencing colleagues, shared contacts, or recent events to build false credibility

Reciprocity

Offering something of value — a prize, gift, or refund — in exchange for sensitive information

Fear

Threats of legal action, account closure, or criminal prosecution to coerce victims into action

- REAL-WORLD SCENARIOS

Pretexting in Practice

Pretexting means fabricating a believable scenario to extract information. These are documented attack patterns from real incidents.

The IT Help Desk Call

Caller claims to be from IT, says your account is compromised, asks you to provide your password to "reset" it

The New Vendor Request

Email appears to be from a vendor updating bank details — finance team redirects a payment to attacker's account

The CEO Wire Transfer

CFO receives an urgent email "from the CEO" requesting a confidential wire transfer before a deadline

The Golden Rule

Any unsolicited request — by phone, email, or in person — for credentials, financial transfers, or sensitive data should be verified through a known, official channel before acting.

Call back using the number on the official website — not the number in the message.

Knowledge Check 1

You receive an email from "support@paypa1.com" saying your account is limited. What should you do first?

Select the best answer:

- A** Click the link in the email to check your account status
- B** Reply to the email asking for more information
- C** Check the sender's email address carefully, then log in to PayPal directly by typing the URL
- D** Forward it to a colleague to see what they think

• DEFENSE

Best Practices to Stay Safe

Enable Multi-Factor Authentication

MFA stops attackers even if they steal your password — use an authenticator app, not SMS

Use a Password Manager

Unique passwords for every account — if one is compromised, others stay secure

Verify Before Clicking

Hover over links to preview the URL — type addresses manually for sensitive sites

Keep Software Updated

Security patches close vulnerabilities that phishing payloads exploit — update promptly

Slow Down on Urgent Requests

Urgency is a manipulation tool — pause, verify through official channels, then act

Report Suspicious Messages

Flag phishing attempts to your security team — you protect everyone by reporting

Protecting Your Credentials

Never share passwords

Legitimate IT staff, banks, and services will never ask for your password

Use passphrases

Three random words beat complex strings:
"PurpleTruckMonday37!" is both secure and memorable

Unique passwords per account

One compromised site should never unlock all your accounts

Check HavelBeenPwned.com

Find out if your email address has appeared in known data breaches

MFA Types — Strongest to Weakest

Hardware key (YubiKey) — strongest

Authenticator app (Google Auth, Authy)

Push notification (Duo, Microsoft Auth)

SMS text message — weakest (SIM swappable)

Never enter an MFA code that was sent after you received an unexpected call or email. This is a real-time phishing attack.

Knowledge Check 2

Your CEO sends you an urgent email at 11pm asking you to wire \$15,000 to a new vendor immediately. What do you do?

Select the best answer:

- A** Wire the money immediately — the CEO is the highest authority in the company
- B** Send a reply email asking for the invoice to confirm details
- C** Check if anyone else in the finance team has seen similar requests
- D** Call the CEO directly on their known phone number to verify the request before taking any action

• INCIDENT RESPONSE

If You've Been Phished

Speed matters. Follow these steps immediately — the faster you act, the less damage occurs.

1 Disconnect

Disconnect your device from the network immediately to prevent malware spread

2 Report

Notify your IT/security team immediately — do not delay or attempt to fix it yourself

3 Change Passwords

Change passwords on the affected account and any account sharing that password

4 Enable MFA

If you haven't already, enable multi-factor authentication on all affected accounts

5 Monitor Accounts

Watch for unauthorized transactions, login alerts, or unusual activity in the following days

6 File a Report

Report to FBI IC3 (reportfraud.ftc.gov) and your organization's security team

Knowledge Check 3

A website's URL starts with HTTPS and shows a padlock. This means the site is safe and legitimate — True or False?

Select the best answer:

- A** True — HTTPS and a padlock always mean a site is legitimate and trustworthy
- B** False — HTTPS only means the connection is encrypted; attackers also use HTTPS on fake sites
- C** True — only verified organizations can obtain HTTPS certificates
- D** False — HTTPS is completely insecure and should never be trusted

TRAINING COMPLETE

You Are the Last Line of Defense

No technical system is perfect. Attackers know this and target the human layer. Your awareness, skepticism, and willingness to verify are the most powerful defenses available.

Stop

Pause before acting on urgent requests

Verify

Confirm through official, known channels

Report

Flag suspicious messages immediately